

-

File No.: EXP202306603

SANCTIONING PROCEDURE RESOLUTION

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

BACKGROUND

FIRST: On April 17, 2023, A.A.A. (hereinafter, the complainant) filed a complaint with the Spanish Agency for Data Protection.

The complaint is directed against HIPERBAZAR YONGFA 2018 SL with NIF B98976194 (hereinafter, the respondent).

The reasons on which the complaint is based are as follows:

The complainant states that the respondent provided images from the video surveillance system of its establishment, in which the complainant appeared, to a third party, and these were disseminated by said third party through their FACEBOOK social media profile.

Screenshots of the publication made on FACEBOOK are provided, where a video from the respondent's video surveillance system is published.

SECOND: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and the guarantee of digital rights (hereinafter LOPDGDD), on May 29, 2023, this complaint was forwarded to the respondent for analysis and to inform this Agency within one month of the actions taken to comply with the requirements set forth in data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was acknowledged on June 7, 2023, as evidenced by the acknowledgment of receipt in the file.

No response has been received to this forwarding letter.

THIRD: On July 17, 2023, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainant was admitted for processing.

FOURTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigative actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section two, of the LOPDGDD, being aware of the following points:

The identification of the owner of the establishment is obtained from the response to the request dated September 13, 2023, to the cadastral owner of the property where the establishment is located: GRELAND, S.L., with NIF B-97431829.

The tenant of the establishment is the company "HIPERBAZAR YONGFA 2018, S.L.", with CIF number B-98976194 and address at Calle Virgen de la Murta No. 56, 46600 Alzira (Valencia).

FIFTH: According to the report obtained from the AXESOR tool, dated 20/11/2023, the entity HIPERBAZAR YONGFA 2018 SL is a small company engaged in the retail trade of non-food industrial products carried out in permanent establishments, established in 2018, with a net turnover of 512,000 euros in 2020.

SIXTH: On December 19, 2023, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the respondent for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified under Article 83.4 of the GDPR and Article 83.5 of the GDPR.

SEVENTH: On January 4, 2024, the aforementioned initiation agreement was notified by postal mail, in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), and after the period granted for the submission of allegations had elapsed, it was confirmed that no allegations had been received from the respondent.

Article 64.2.f) of the LPACAP - a provision of which the respondent was informed in the initiation

agreement - establishes that if no allegations are made within the stipulated period regarding the content of the initiation agreement, when it contains a precise statement regarding the responsibility attributed, it may be considered a proposal for resolution. In this case, the initiation agreement of the sanctioning file determined the facts underlying the accusation, the infringement of the GDPR attributed to the respondent, and the sanction that could be imposed. Therefore, considering that the respondent has not made any allegations to the initiation agreement of the file and in accordance with the provisions of Article 64.2.f) of the LPACAP, the aforementioned initiation agreement is considered in this case as a proposal for resolution.

In view of all that has transpired, the Spanish Agency for Data Protection considers the following facts to be proven in this procedure,

PROVEN FACTS

FIRST: The respondent has a video surveillance system in its establishment that can capture images of the parking area.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/12

SECOND: The respondent has provided images obtained through the video surveillance system of its establishment, in which the claimant appeared and which allowed a third party to identify the license plate of their vehicle parked in the establishment's parking lot.

THIRD: This third party has disseminated the aforementioned images through their Facebook profile.

FOURTH: On December 19, 2023, the initiation of sanctioning proceedings was agreed upon, notified to the respondent on December 4. After the period granted for this purpose, the respondent has not made any allegations.

LEGAL GROUNDS

I

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, this organic law, the regulatory provisions issued for its development, and, in so far as they do not contradict them, by the general rules on administrative procedures in a subsidiary manner."

II

Preliminary Issues

In this case, the claimant states that the respondent provided images from the video surveillance system of its establishment, in which the image of the claimant appeared, to a third party, which were then disseminated by that third party through their FACEBOOK social media profile.

The respondent carries out this activity in its capacity as the data controller, as it is the one who determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR:

“‘data controller’ or ‘controller’: the natural or legal person, public authority, agency, or other body that, alone or jointly with others, determines the purposes and means of the processing; where the purposes and means of that processing are determined by Union or Member State law, the controller or the specific criteria for its designation may be provided for by Union or Member State law.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

4/12

Article 4(12) of the GDPR broadly defines “personal data breaches” (hereinafter security breach) as “a breach of security leading to the accidental or unlawful destruction, loss, alteration, unauthorized disclosure of, or access to, personal data transmitted, stored, or otherwise processed.”

In this regard, it should be noted that such access to the personal data of the claimants constitutes a personal data breach, categorized as a breach of confidentiality.

According to the GT29, a “Confidentiality Breach” occurs when there is an unauthorized or accidental disclosure of personal data, or access to it.

It should be noted that the identification of a security breach does not directly imply the imposition of a sanction by this Agency, as it is necessary to analyze the diligence of the controllers and processors and the security measures applied.

Within the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data are guaranteed in paragraph 1(f) of Article 5 of the GDPR. In turn, the security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which govern the security of processing, the notification of a personal data breach to the supervisory authority, and the communication to the data subject, respectively.

III

Article 5.1(f) of the GDPR

Article 5.1(f) of the GDPR states the following:

“Article 5 Principles relating to processing:

1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction, or damage, using appropriate technical or organizational measures (‘integrity and confidentiality’).”

In relation to this principle, Recital 39 of the aforementioned GDPR states:

“[...] Personal data should be processed in a manner that ensures appropriate security and confidentiality of the personal data, including to prevent unauthorized access or use of such data and the equipment used for processing.”

The documentation in the file provides clear indications that the respondent violated Article 5.1(f) of the GDPR, principles relating to processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

5/12

In the present case, the claiming party alleges that the responding party provided images from the video surveillance system of its establishment, in which the claiming party appeared, to a third party, and these were disseminated by said third party through their FACEBOOK social media profile.

In accordance with the available evidence, it is considered that the known facts constitute an infringement attributable to the responding party for violation of Article 5.1.f) of the GDPR.

IV

Classification of the infringement of Article 5.1.f) of the GDPR

The aforementioned infringement of Article 5.1.f) of the GDPR could constitute the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” states:

“Violations of the following provisions shall be subject to administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

a) the basic principles for processing, including the conditions for consent under Articles 5, 6, 7, and 9; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements,” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that

are contrary to this organic law, constitute infringements."

For the purposes of the statute of limitations, Article 72 "Very serious infringements" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements are considered very serious and shall be subject to a three-year statute of limitations:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

V

Article 32 of the GDPR

Article 32 of the GDPR, concerning the security of processing, states the following:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

a) the pseudonymization and encryption of personal data;

b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;

c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;

d) a process for regularly testing, assessing, and evaluating the effectiveness of technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a result of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data only processes such data on instructions from the controller, unless required to do so by Union or Member State law."

It should be noted that the GDPR in the aforementioned provision does not establish a list of security measures applicable according to the data being processed, but rather states that the controller and the processor shall implement technical and organizational measures that are appropriate to the risk posed by the processing, taking into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, and the risks of varying probability and severity for the rights and freedoms of the data subjects.

Furthermore, the security measures must be adequate and proportionate to the identified risk, indicating that the determination of technical and organizational measures should be made considering: pseudonymization and encryption, the ability to ensure confidentiality, integrity, availability, and resilience, the ability to restore availability and access to data after an incident, and a process of verification (which is not an audit), assessment, and evaluation of the effectiveness of the measures.

In any case, when assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, as a result of the accidental or unlawful destruction, loss, or alteration of data.

7/12

personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data that could cause physical, material, or immaterial damages.

In this same sense, recital 83 of the GDPR states that:

"(83) In order to maintain security and prevent processing from infringing the provisions of this

Regulation, the controller or the processor must assess the inherent risks of the processing and implement measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation concerning the risks and the nature of the personal data that must be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be taken into account, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data, particularly those that could cause physical, material, or immaterial damages.”

The liability of the respondent is determined by the lack of security measures, as they are responsible for making decisions aimed at effectively implementing appropriate technical and organizational measures to ensure an adequate level of security concerning the risk to ensure the confidentiality of the data, restoring its availability, and preventing access to it in the event of a physical or technical incident.

In accordance with the available evidence, it is considered that the known facts constitute an infringement attributable to the respondent for violation of Article 32 of the GDPR.

VI

Classification of the infringement of Article 32 of the GDPR

The aforementioned infringement of Article 32 of the GDPR could constitute the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading “General conditions for the imposition of administrative fines” provides:

“Violations of the following provisions shall be subject to administrative fines of up to 10,000,000 EUR or, in the case of an enterprise, an amount equivalent to up to 2% of the total global annual turnover of the preceding financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)”

In this regard, the LOPDGDD, in its Article 71 “Infringements,” establishes that “Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements.”

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/12

For the purposes of the limitation period, Article 73 “Infringements considered serious” of the LOPDGDD indicates:

“Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following infringements are considered serious and shall be subject to a limitation period of two years, which involve a substantial violation of the articles mentioned therein and, in particular, the following:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure an adequate level of security concerning the risk of processing, as required by Article 32.1 of Regulation (EU) 2016/679.”

VII

Sanction

In order to determine the administrative fine to be imposed, the provisions of Articles 83.1 and 83.2 of the GDPR must be observed, which state:

“1. Each supervisory authority shall ensure that the imposition of administrative fines under this article for the infringements of this Regulation indicated in paragraphs 4, 5, and 6 is, in each individual case, effective, proportionate, and dissuasive.

2. Administrative fines shall be imposed, depending on the circumstances of each individual case, as an additional or substitute measure to those provided for in Article 58, paragraph 2, letters a) to h) and j). In deciding on the imposition of an administrative fine and its amount in each individual case, the following shall be duly taken into account:

a) the nature, gravity, and duration of the infringement, taking into account the nature, scope, or

purpose of the processing operation in question, as well as the number of data subjects affected and the level of damages suffered;

b) the intentionality or negligence in the infringement;

c) any measures taken by the controller or processor to mitigate the damages suffered by the data subjects;

d) the degree of responsibility of the controller or processor, taking into account the technical or organizational measures they have implemented under Articles 25 and 32;

e) any previous infringement committed by the controller or processor;

f) the degree of cooperation with the supervisory authority in order to remedy the infringement and mitigate the possible adverse effects of the infringement;

g) the categories of personal data affected by the infringement;

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

9/12

h) the manner in which the supervisory authority became aware of the infringement, in particular whether the controller or the processor notified the infringement and, if so, to what extent;

i) when the measures indicated in Article 58, paragraph 2, have been previously ordered against the controller or the processor in relation to the same matter, the compliance with such measures;

j) adherence to codes of conduct under Article 40 or to certification mechanisms approved under Article 42;

k) any other aggravating or mitigating factor applicable to the circumstances of the case, such as the financial benefits obtained or the losses avoided, directly or indirectly, through the infringement.”

For its part, Article 76 “Sanctions and corrective measures” of the LOPDGDD states:

“1. The sanctions provided for in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679 shall be applied taking into account the criteria for graduation established in paragraph 2 of the aforementioned article.

2. In accordance with the provisions of Article 83.2.k) of Regulation (EU) 2016/679, the following may also be taken into account:

a) The ongoing nature of the infringement.

b) The connection of the infringer's activity with the processing of personal data.

c) The benefits obtained as a result of the commission of the infringement.

d) The possibility that the conduct of the affected party may have induced the commission of the infringement.

e) The existence of a merger by absorption after the commission of the infringement, which cannot be attributed to the absorbing entity.

f) The impact on the rights of minors.

g) Having, when not mandatory, a data protection officer.

h) The voluntary submission by the controller or processor to alternative dispute resolution mechanisms, in cases where there are disputes between them and any interested party.”

Sanction for the infringements of Articles 5.1.f) and 32 of the GDPR.

In accordance with the transcribed provisions, and without prejudice to what results from the instruction of the procedure, for the purpose of determining the amount of the sanction for the infringement of Article 5.1 f), it is appropriate to graduate the fine taking into account:

Considering the factors presented, the amount of the fine is €3,000 for the infringement of Article 5.1 f) of the GDPR, regarding the breach of the principle of confidentiality, and €2,000 for the infringement of Article 32 of the aforementioned GDPR, regarding the security of the processing of personal data, which totals €5,000.

VIII

Liability

The Law 40/2015, of October 1, on the Legal Regime of the Public Sector, establishes in Chapter III regarding the “Principles of the Sanctioning Power,” in Article 28 under the heading “Liability,” the

following:

“1. Only individuals and legal entities may be sanctioned for acts constituting administrative infringement, as well as, when a law recognizes their capacity to act, groups of affected parties, unions and entities without legal personality, and independent or autonomous assets, that are found responsible for the same by way of intent or negligence.”

The lack of diligence in implementing appropriate security measures resulting in the breach of the principle of confidentiality constitutes the element of culpability.

IX

Measures

In accordance with the aforementioned Article 58.2 d) of the GDPR, under which each supervisory authority may “order the controller or processor to ensure that the processing operations comply with the provisions of this Regulation, where appropriate, in a specific manner and within a specified timeframe...”.

Specifically, the adoption of the necessary technical and organizational measures to prevent the breach of the confidentiality principle of the processed personal data is required.

The imposition of this measure is compatible with the sanction consisting of an administrative fine, as provided in Article 83.2 of the GDPR.

It is noted that failure to comply with the requirements of this body may be considered an administrative infringement in accordance with the provisions of the GDPR, classified as an infringement in its Articles 83.5 and 83.6, which may lead to the initiation of a further administrative sanctioning procedure.

Therefore, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

11/12

FIRST: TO IMPOSE on HIPERBAZAR YONGFA 2018 SL, with NIF B98976194, a fine of €3,000 (three thousand euros) for an infringement of Article 5.1.f) of the GDPR and a fine of €2,000 (two thousand euros) for Article 32 of the GDPR, as classified in Article 83.5 of the GDPR and Article 83.4 of the GDPR, totaling €5,000 (five thousand euros).

SECOND: TO ORDER HIPERBAZAR YONGFA 2018 SL, with NIF B98976194, to, pursuant to Article 58.2.d) of the GDPR, within one month from the date this resolution becomes final and enforceable, provide evidence of having adopted the necessary technical and organizational measures to avoid breaching the principle of confidentiality of the personal data processed.

THIRD: TO NOTIFY this resolution to HIPERBAZAR YONGFA 2018 SL.

FOURTH: This resolution will be enforceable once the period for filing the optional appeal for reconsideration (one month from the day following the notification of this resolution) has expired without the interested party having exercised this right. The sanctioned party is warned that they must comply with the imposed sanction once this resolution becomes enforceable, in accordance with the provisions of Article 98.1.b) of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter LPACAP), within the voluntary payment period established in Article 68 of the General Collection Regulation, approved by Royal Decree 939/2005, of July 29, in relation to Article 62 of Law 58/2003, of December 17, by making the payment, indicating the NIF of the sanctioned party and the procedure number that appears in the heading of this document, into the restricted account No. IBAN: ES00-0000-0000-0000-0000-0000 (BIC/SWIFT Code: CAIXESBBXXX), opened in the name of the Spanish Agency for Data Protection at the banking entity CAIXABANK, S.A. Otherwise, collection will proceed in the executive period.

Upon receipt of the notification and once enforceable, if the date of enforceability falls between the 1st and the 15th of each month, inclusive, the deadline for voluntary payment will be until the 20th of the following month or the next business day thereafter, and if it falls between the 16th and the last day of

each month, inclusive, the payment deadline will be until the 5th of the second following month or the next business day thereafter.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file an appeal for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file a contentious-administrative appeal before the Contentious-Administrative Chamber of the National Court, in accordance with the provisions of Article 25 and Section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Contentious-Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law. Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file a contentious-administrative appeal. If this is the case, the interested party must formally communicate this fact by writing to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in Article 16.4 of Law 39/2015, of October 1. They must also provide the Agency with documentation evidencing the effective filing of the contentious-administrative appeal. If the Agency is not aware of the filing of the contentious-administrative appeal within two months from the day following the notification of this resolution, the provisional suspension will be considered terminated.

938-16012024

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es